

مستند فنی سامانه AI Chat SaaS

Technical Documentation

پلتفرم چندمستاجری چت پشتیبانی، ویجت سایت و دستیار هوشمند مبتنی بر دانش

AI Chat SaaS

مستند فنی

۰.۱

۱۴ جولای ۲۰۲۶

مبین یوسفی

doc/LaTeX/03-Technical-Documentation.tex

نام پروژه:

نوع سند:

نسخه سند:

تاریخ:

نویسنده/تهیه کننده:

مسیر سند:

این سند برای ارائه فنی پروژه، اثبات بلوغ مهندسی نرم افزار، تشریح معماری و مستندسازی مازول های اصلی سامانه تهیه شده است.

فهرست مطالب

۲	۱ هدف و دامنه سند
۲	۲ معرفی کامل سیستم
۲	۱.۲ اهداف محصول
۲	۲.۲ کاربران و نقش‌ها
۳	۳ معماری نرم‌افزار
۳	۱.۳ نمای کلی معماری
۳	۲.۳ نمودار متنی اجزا
۴	۳.۳ اصل چندمستاجری
۴	۴ فناوری‌های استفاده شده
۵	۵ وابستگی‌ها و Dependency
۵	۱.۵ وابستگی‌های Frontend
۵	۲.۵ وابستگی‌های Backend
۵	۳.۵ متغیرهای محیطی مهم
۵	۶ ساختار Repository
۶	۱.۶ توضیح پوشه‌های اصلی
۷	۷ مازول‌ها و سرویس‌های اصلی
۷	۱.۷ مازول احراز هویت
۷	۲.۷ مازول دسترسی سایت
۷	۳.۷ مازول ویجت عمومی
۷	۴.۷ مازول مکالمات و پشتیبانی انسانی
۸	۵.۷ مازول فایل‌های پیوست
۸	۶.۷ مازول پلن و محدودیت مصرف
۸	۷.۷ مازول دانش و AI
۸	۸ Workflow سیستم
۸	۱.۸ جریان نصب و راه‌اندازی مشتری
۹	۲.۸ جریان مکالمه بازدیدکننده
۹	۳.۸ جریان پیشنهاد پاسخ AI برای اپراتور

۹	۴.۸ جریان پاسخ خودکار AI
۱۰	۹ موتور پاسخ‌دهی هوشمند
۱۰	۱.۹ Pipeline فنی
۱۰	۲.۹ چرایی انتخاب رویکرد استخراجی
۱۱	۳.۹ Crawler و آماده‌سازی دانش
۱۱	۱۰ ساختار پایگاه داده
۱۱	۱.۱۰ جداول اصلی استنباط‌شده
۱۲	۲.۱۰ جداول AI موجود در migration
۱۲	۱۱ API و گروه‌ها Endpoint
۱۲	۱.۱۱ گروه Auth
۱۲	۲.۱۱ گروه Widget
۱۳	۳.۱۱ گروه Agent
۱۳	۴.۱۱ گروه Admin Customer
۱۳	۵.۱۱ گروه Admin Super
۱۳	۱۲ Design Pattern و تصمیم‌های معماری
۱۳	۱.۱۲ Endpoint-per-file
۱۳	۲.۱۲ Includes Shared
۱۴	۳.۱۲ Repository/Service سبک در Frontend
۱۴	۴.۱۲ Access Policy-based
۱۴	۵.۱۲ AI Knowledge-grounded
۱۴	۱۳ امنیت و کنترل سوءاستفاده
۱۴	۱.۱۳ نکات امنیتی نیازمند بازبینی قبل از تولید
۱۵	۱۴ Flow Git و مدیریت نسخه
۱۵	۱۵ کیفیت، تست و پایش
۱۵	۱۶ محدودیت‌های فعلی و ریسک‌های فنی
۱۶	۱۷ جمع‌بندی فنی

۱ هدف و دامنه سند

این سند، مستند فنی پروژه SaaS Chat AI است و با هدف توضیح دقیق سیستم، معماری نرم افزار، ساختار کد، ماژول ها، سرویس ها، وابستگی ها، جریان های عملیاتی، الگوهای طراحی، مدل امنیت و محدودیت های فعلی تهیه شده است.

دامنه این سند شامل سه لایه اصلی محصول است:

- بک اند PHP و MySQL برای مدیریت داده، احراز هویت، چندمستاجری، APIها، چت، دانش و موتور پاسخ دهی.
 - پنل مدیریتی Next.js/React برای سوپرادمین، ادمین مشتری و اپراتور پشتیبانی.
 - ویجت JavaScript قابل نصب روی سایت مشتری برای چت عمومی بازدیدکنندگان.
- این سند بر اساس بررسی فایل های `doc/md/ArchitectureForMobin.md`، `doc/md/Rahnama.md` و `doc/md/ReportForSale.md` و فایل های کد کلیدی پروژه نوشته شده است.

۲ معرفی کامل سیستم

SaaS Chat AI یک سامانه نرم افزاری چندمستاجری برای پشتیبانی آنلاین وبسایت ها است. هر مشتری می تواند یک یا چند سایت را در سامانه ثبت کند، ویجت چت را با `site_key` روی سایت خود نصب کند، مکالمات بازدیدکنندگان را در پنل مدیریتی ببیند و با کمک اپراتور انسانی یا پاسخ هوشمند مبتنی بر دانش به کاربران پاسخ دهد.

ویژگی مهم سیستم این است که محصول فقط یک چت بات نیست؛ بلکه یک سکوی کامل پشتیبانی شامل کنترل پنل، مدیریت مشتریان، پلن ها، تیم پشتیبانی، مکالمات، فایل های پیوست، دانش دستی، خزش وبسایت، پیشنهاد پاسخ هوشمند، پاسخ خودکار در زمان آفلاین بودن پشتیبانی و حلقه بهبود دانش است.

۱.۲ اهداف محصول

- فراهم کردن کانال چت نصب شدنی برای سایت های مشتریان.
- مدیریت مکالمات بازدیدکنندگان توسط ادمین ها و اپراتورها.
- پاسخ گویی سریع تر با پیشنهاد های هوشمند مبتنی بر دانش سایت.
- پاسخ خودکار به سوالات متداول در زمان آفلاین بودن پشتیبانی.
- ایجاد چرخه یادگیری از سوالات بی پاسخ و تبدیل آن ها به دانش قابل استفاده.
- فراهم کردن ساختار تجاری SaaS شامل پلن، محدودیت مصرف، مشتری، سایت و تیم.

۲.۲ کاربران و نقش ها

نقش مسئولیت ها و سطح دسترسی

سوپرادمین	مالک پلتفرم؛ مدیریت مشتریان، پلن‌ها، سایت‌ها، کاربران، وضعیت مشتری، اعلان‌ها و آمار کلی سامانه.
ادمین مشتری	مدیر کسب‌وکار مشتری؛ مدیریت سایت‌های خود، تنظیمات ویجت، تیم، دانش، AI، گزارش‌ها و مصرف پلن.
اپراتور/Agent	کاربر پشتیبانی؛ مشاهده مکالمات مجاز، پاسخ‌گویی، ارسال فایل، استفاده از پاسخ سریع، دریافت پیشنهاد AI و تغییر وضعیت مکالمه.
بازدیدکننده سایت	کاربر عمومی؛ شروع مکالمه از ویجت، ارسال پیام و فایل، دریافت پاسخ انسانی یا پاسخ AI.

۳ معماری نرم‌افزار

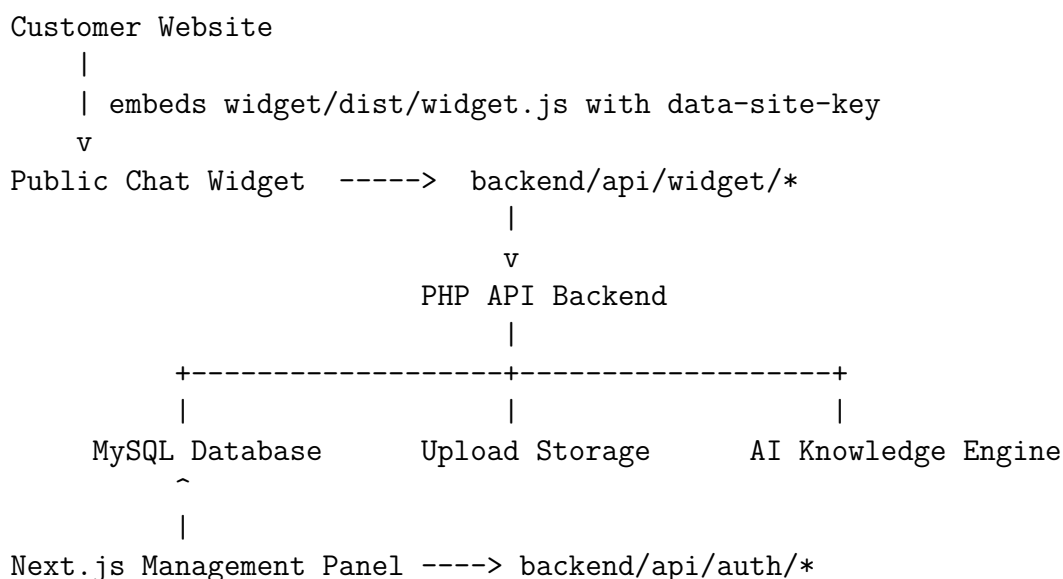
۱.۳ نمای کلی معماری

معماری پروژه از چهار بخش اصلی تشکیل شده است:

- **Backend:** مجموعه‌های API مستقل PHP که از طریق PDO به MySQL متصل می‌شوند.
- **Frontend:** پنل مدیریتی مبتنی بر Next.js و React.
- **Widget:** اسکریپت جاوااسکریپت قابل جاسازی در سایت مشتری با Shadow DOM.
- **Shop: Test** سایت آزمایشی برای تست ویجت و جریان چت.

بک‌اند یک اپلیکیشن فریم‌ورکی نیست. هر endpoint به صورت یک فایل مستقل در مسیر backend/api/... پیاده‌سازی شده و منطق مشترک در مسیر backend/includes/... قرار دارد. این ساختار برای MVP و توسعه سریع مناسب است و باعث می‌شود افزودن endpoint جدید با اضافه کردن یک فایل PHP و include کردن‌های helper لازم انجام شود.

۲.۳ نمودار متنی اجزا



```

----> backend/api/agent/*
----> backend/api/customer/*
----> backend/api/super-admin/*

```

۳.۳ اصل چندمستاجری

سامانه بر پایه جداسازی داده در سطح tenant و site طراحی شده است. مشتریان در جدول tenants نگهداری می‌شوند و هر مشتری می‌تواند چند سایت در جدول sites داشته باشد. کاربران غیرسوپرادمین به یک tenant_id وابسته‌اند و دسترسی آن‌ها به سایت‌ها از طریق نقش و جدول agent_site_access کنترل می‌شود.

در این مدل:

- سوپرادمین به همه سایت‌ها و مشتریان دسترسی دارد.
- ادمین مشتری فقط به داده‌های مستاجر خود دسترسی دارد.
- اپراتور فقط به سایت‌هایی دسترسی دارد که به او اختصاص داده شده است.
- های‌endpoint عمومی ویجت به‌جای JWT با site_key، وضعیت سایت، وضعیت ten-ant، CORS و limit rate کنترل می‌شوند.

۴ فناوری‌های استفاده شده

لایه	فناوری‌ها و توضیح
Backend	PHP خام، PDO، MySQL، های‌endpoint فایل‌محور، JSON، API، JWT با الگوریتم HS۲۵۶
Frontend	Next.js، React، TypeScript، CSS، مازولار در پوشه frontend/styles
Widget	JavaScript، Vanilla، DOM، Shadow، LocalStorage، Fetch، API، polling برای پیام‌ها و typing.
Database	MySQL/InnoDB، کلید خارجی، ایندکس‌های معمولی و FULLTEXT در جداول AI.
AI/KM	موتور محلی مبتنی بر نرمال‌سازی متن، استخراج token، تشخیص intent، جست‌وجوی LIKE/FULLTEXT، امتیازدهی و پاسخ استخراجی.
Security	JWT، role-based، access، site access، CORS، origin، validation، security، headers، rate dation، limit،
Config	فایل .env و فایل‌های backend/config/app.php و backend/config/database.php

۵ وابستگی‌ها و وابستگی‌ها

۱.۵ وابستگی‌های Frontend

بر اساس frontend/package.json وابستگی‌های اصلی پنل عبارت‌اند از:

- next: فریم‌ورک اصلی پنل مدیریتی.
- react و react-dom: ساخت رابط کاربری.
- typescript: تایپ‌گذاری و توسعه پایدارتر کد frontend.
- tailwindcss: وابستگی توسعه‌ای موجود در پروژه، هرچند بخش مهمی از استایل‌ها از فایل‌های CSS اختصاصی استفاده می‌کند.

۲.۵ وابستگی‌های Backend

بک‌اند بر پایه کتابخانه خارجی سنگین طراحی نشده و عمدتاً از امکانات استاندارد PHP استفاده می‌کند:

- PDO: اتصال امن‌تر به MySQL و اجرای های‌های prepared.
- curl یا file_get_contents: دریافت صفحات توسط crawler.
- DOMDocument و DOMXPath: استخراج محتوای خوانا از HTML.
- توابع استاندارد رمزنگاری و hash برای JWT، نام فایل تصادفی و hash محتوا.

۳.۵ متغیرهای محیطی مهم

فایل backend/.env.example متغیرهای زیر را مستند کرده است:

- تنظیمات برنامه: APP_ENV، APP_DEBUG، APP_TIMEZONE، FRONTEND_URL، API_URL.
- پایگاه داده: DB_HOST، DB_NAME، DB_USER، DB_PASS.
- احراز هویت: JWT_SECRET، JWT_EXPIRATION_SECONDS، JWT_ISSUER، JWT_AUDIENCE.
- Provider: AI و OPENAI_API_KEY. در جریان فعال فعلی، پاسخ‌دهی اصلی عمدتاً محلی و استخراجی است.
- آپلود: UPLOAD_MAX_BYTES، UPLOAD_MAX_IMAGE_PIXELS، UPLOAD_PUBLIC_URL، UPLOAD_STORAGE_ROOT.
- CORS: PANEL_ALLOWED_ORIGINS، WIDGET_ALLOWED_ORIGINS، WIDGET_ALLOW_EMPTY_ORIGIN.

۶ ساختار Repository

ai-chat-saas/

```

|-- backend/
|   |-- api/
|   |   |-- auth/
|   |   |-- widget/
|   |   |-- agent/
|   |   |-- customer/
|   |   |-- `-- super-admin/
|   |-- config/
|   |-- database/migrations/
|   |-- includes/
|   |-- public/
|   |-- `-- storage/
|-- frontend/
|   |-- app/
|   |-- components/
|   |-- lib/
|   |-- public/
|   |-- `-- styles/
|-- widget/
|   |-- src/
|   |-- `-- dist/
|-- test-shop/
`-- doc/
    |-- md/
    |-- `-- LaTeX/

```

۱.۶ توضیح پوشه‌های اصلی

مسیر	شرح
backend/api/auth	ورود، دریافت کاربر جاری، تغییر رمز و خروج از همه دستگاه‌ها.
backend/api/widget	API عمومی ویجت شامل تنظیمات، شروع بازدیدکننده، شروع مکالمه، ارسال پیام، فایل، لیست پیام‌ها، typing و پاسخ AI.
backend/api/agent	API اپراتور برای مکالمات، ارسال پاسخ، پیوست، assignment، وضعیت، replies quick presence و پیشنهاد AI.
backend/api/customer	مدیریت سایت‌ها، تیم، گزارش، quick، replies، دانش، تنظیمات AI، crawl، سوالات تولیدشده و سوالات بی‌پاسخ.
backend/api/super-admin	داشبورد پلتفرم، مشتریان، پلن‌ها، سایت‌ها، کاربران، اعلان‌ها و مانیتورینگ AI.
backend/includes	های مشترک شامل، auth، JWT، response، CORS، limits plan access، site limit، rate upload، headers، curity و موتور AI.
frontend/app	صفحات پنل مدیریتی Next.js برای نقش‌های مختلف.

frontend/lib/api.ts لایه مرکزی ارتباط frontend با API و مدیریت token در local-Storage.

widget/src/widget.js سورس ویجت قابل نصب روی سایت مشتری.

widget/dist/widget.js خروجی قابل انتشار ویجت.

۷ مازول‌ها و سرویس‌های اصلی

۱.۷ مازول احراز هویت

احراز هویت پنل از طریق JWT انجام می‌شود. endpoint ورود پس از اعتبارسنجی ایمیل و رمز عبور، token صادر می‌کند. فایل backend/includes/auth.php وظیفه استخراج Bearer Token، code کردن JWT، بررسی کاربر، فعال بودن حساب، بررسی token_version و اعتبار tenant را بر عهده دارد.

payload توکن شامل فیلدهایی مانند sub, tenant_id, email, role, token_version, jti, iat, exp, nbf, iss و aud است. وجود token_version باعث می‌شود تغییر رمز یا logout-all بتواند توکن‌های قبلی را باطل کند.

۲.۷ مازول دسترسی سایت

کنترل دسترسی سایت در backend/includes/site-access.php متمرکز شده است. این مازول مانع IDOR بین tenantها و سایت‌ها می‌شود. سوپرادمین دسترسی کامل دارد، ادمین مشتری به سایت‌های tenant خود محدود است و اپراتور از طریق agent_site_access مجوز می‌گیرد.

۳.۷ مازول ویجت عمومی

ویجت با یک tag script و مقدار data-site-key نصب می‌شود. ویجت ابتدا تنظیمات سایت را از widget/config.php می‌گیرد، سپس با browser_id ذخیره شده در LocalStorage بازدیدکننده را ایجاد یا بازیابی می‌کند. مکالمه از طریق conversation-start.php شروع می‌شود و پیام‌ها از طریق message-send.php ارسال می‌شوند.

ویژگی‌های فنی ویجت:

- استفاده از Shadow DOM برای جلوگیری از تداخل CSS سایت میزبان.
- ذخیره browser_id، اطلاعات visitor و conversation در LocalStorage.
- polling با بازه تقریبی ۵.۲ ثانیه برای پیام‌ها و typing.
- کنترل client-side برای حجم و نوع فایل.
- پشتیبانی از پیام‌های visitor، agent، AI و system.
- نمایش راست‌چین و مناسب زبان فارسی.

۴.۷ مازول مکالمات و پشتیبانی انسانی

مکالمات در جدول conversations و پیام‌ها در جدول messages ذخیره می‌شوند. اپراتورها و ادمین‌ها از مسیر backend/api/agent مکالمات را مشاهده و مدیریت می‌کنند. endpointهای مهم شامل conversation-show.php، conversations-list.php، conversation-status-update.php، conversation-close.php هستند.

وضعیت‌های مکالمه در کد شامل new، open، in_progress، waiting_customer، follow_up، closed و pending است.

۵.۷ مازول فایل‌های پیوست

فایل‌های پیوست از سمت visitor و agent قابل ارسال هستند. منطق مشترک validation در backend/includes/upload.php قرار دارد. نوع‌های مجاز شامل GIF، PNG، JPG، WebP و PDF است. کنترل‌ها شامل محدودیت حجم، MIME، پسوند، جلوگیری از پسوندهای خطرناک، اسکن محتوای HTML/SVG/Executable، بررسی محتوای فعال، PDF کنترل ابعاد تصویر و تولید نام تصادفی است.

۶.۷ مازول پلن و محدودیت مصرف

فایل backend/includes/plan-limits.php مسئول خواندن پلن tenant و اعمال محدودیت‌ها است. محدودیت‌ها شامل تعداد سایت، تعداد agent، تعداد مکالمات ماهانه، فعال بودن پیشنهاد AI، پاسخ خودکار AI و دانش هستند. تابع ensure_monthly_conversation_limit قبل از ایجاد مکالمه جدید، مصرف ماهانه tenant را بررسی می‌کند.

۷.۷ مازول دانش و AI

AI فعال پروژه یک موتور محلی، قابل کنترل و مبتنی بر دانش ذخیره‌شده است. این موتور در مسیرهای backend/includes/ai-crawler.php، backend/includes/ai-answer-engine.php و backend/includes/ai-helpers.php پیاده‌سازی شده است.

منابع دانش:

- دانش دستی در جدول knowledge_sources.
- صفحات crawl شده در جدول ai_pages.
- های chunk متنی در جدول ai_content_chunks.
- terms استخراج شده در جدول ai_terms.
- سوالات قالبی تولید شده در جدول ai_generated_questions.

این طراحی وابستگی عملیاتی پاسخ‌دهی روزمره به سرویس خارجی را کاهش می‌دهد و پاسخ‌ها را به محتوای تایید شده مشتری نزدیک نگه می‌دارد.

۸ Workflow سیستم

۱.۸ جریان نصب و راه اندازی مشتری

۱. سوپرادمین یک مشتری جدید ایجاد می کند.
۲. برای مشتری یک tenant، یک سایت اولیه، یک site_key و یک کاربر admin customer ساخته می شود.
۳. مشتری کد نصب ویجت را دریافت می کند.
۴. مشتری ویجت را روی سایت خود نصب می کند.
۵. مشتری تنظیمات برند، رنگ، پیام خوشامد و حالت AI را تعیین می کند.
۶. مشتری دانش دستی اضافه می کند یا منابع crawl را تعریف می کند.
۷. agent ها مکالمات ورودی را در پنل پاسخ می دهند.

۲.۸ جریان مکالمه بازدیدکننده

۱. ویجت با site_key بارگذاری می شود.
۲. ویجت از widget/config.php تنظیمات عمومی سایت و وضعیت آنلاین پشتیبانی را می گیرد.
۳. بازدیدکننده نام، ایمیل یا شماره تماس و پیام اولیه را وارد می کند.
۴. visitor-start.php بازدیدکننده را ثبت یا به روزرسانی می کند.
۵. conversation-start.php مکالمه فعال را برمی گرداند یا مکالمه جدید می سازد.
۶. پیام visitor در message-send.php ذخیره می شود.
۷. اگر پشتیبانی آنلاین نباشد و AI مجاز باشد، ویجت ai-reply.php را فراخوانی می کند.
۸. agent ها مکالمه را در پنل می بینند و می توانند ادامه دهند.

۳.۸ جریان پیشنهاد پاسخ AI برای اپراتور

۱. agent یا admin customer مکالمه را باز می کند.
۲. ai-suggestion-generate.php endpoint آخرین پیام visitor را پیدا می کند.
۳. سیستم فعال بودن ویژگی ai_suggestions_enabled در پنل را بررسی می کند.
۴. تابع ai_find_best_answer روی دانش سایت اجرا می شود.
۵. اگر امتیاز از min_suggestion_score بیشتر باشد، پیشنهاد در ai_suggestions ذخیره می شود.
۶. نتیجه در ai_answer_logs ثبت می شود.
۷. اگر امتیاز کافی نباشد، سوال در ai_unanswered_questions ذخیره می شود.

۴.۸ جریان پاسخ خودکار AI

۱. ویجت پس از ارسال پیام، widget/ai-reply.php visitor را با message_id فراخوانی می‌کند.
۲. endpoint اعتبار site_key، visitor، conversation، message وضعیت سایت، وضعیت tenant و origin را بررسی می‌کند.
۳. اگر conversation بسته باشد، AI خاموش باشد، assistant غیرفعال باشد یا پشتیبانی آنلاین باشد، پاسخ خودکار انجام نمی‌شود.
۴. از ارسال پاسخ تکراری برای یک پیام جلوگیری می‌شود.
۵. موتور پاسخ‌دهی محلی بهترین پاسخ را پیدا و confidence را محاسبه می‌کند.
۶. اگر confidence از min_auto_reply_score بالاتر باشد، پیام با ai sender_type = درج می‌شود.
۷. در غیر این صورت message fallback ارسال و سوال برای بررسی بعدی ذخیره می‌شود.

۹ موتور پاسخ‌دهی هوشمند

۱.۹ Pipeline فنی

- تابع اصلی پاسخ‌دهی ai_find_best_answer است. این تابع مراحل زیر را اجرا می‌کند:
۱. نرمال‌سازی متن سوال با تبدیل حروف عربی به فارسی و حذف فاصله‌های زائد.
 ۲. استخراج‌های token معنادار و حذف stop های word فارسی و انگلیسی.
 ۳. تشخیص intent و category با قواعد کلیدواژه‌ای مانند pricing، contact، appoint- service، shipping ment،
 ۴. جست‌وجو در دانش دستی، سوالات تولیدشده و های crawl chunk شده.
 ۵. محاسبه امتیاز تطابق بر اساس نسبت های token پیدا شده، وزن طول token، تطابق تقریبی سوال و های boost منبع.
 ۶. اعمال boost برای دانش دستی، FAQ، intent/category مشابه، های term استخراج‌شده و score. importance
 ۷. انتخاب بهترین candidate و ساخت پاسخ استخراجی کوتاه از متن منبع.
 ۸. برگرداندن answer، confidence، sources best و candidates.

۲.۹ چرایی انتخاب رویکرد استخراجی

در نسخه فعلی، موتور فعال بیشتر محلی و استخراجی است؛ یعنی به جای تولید آزاد متن، پاسخ را از منابع دانش مشتری استخراج می‌کند. این تصمیم برای سامانه پشتیبانی مزیت دارد، چون:

- پاسخ‌ها به محتوای تاییدشده مشتری محدود می‌شوند.
- ریسک hallucination کاهش می‌یابد.

- قابلیت توضیح‌پذیری بیشتر است، چون source و score ذخیره می‌شود.
- هزینه عملیاتی و وابستگی به API خارجی کمتر می‌شود.
- سوالات کم‌اعتماد به جای پاسخ اشتباه، وارد صف بازبینی می‌شوند.

۳.۹ Crawler و آماده‌سازی دانش

خزشگر سایت در `backend/includes/ai-crawler.php` پیاده‌سازی شده و از منابع `url`، `path_prefix` و `sitemap` پشتیبانی می‌کند. `crawler` صفحات مجاز دامنه مشتری را دریافت می‌کند، عنوان، `meta`، `description`، متن خوانا و لینک‌ها را استخراج می‌کند، متن را `chunk` می‌کند، `term` استخراج می‌کند و از هر `chunk` چند سوال قالبی می‌سازد.

خروجی‌های اصلی `crawler`:

- `ai_pages`: متن پاک‌سازی‌شده و `metadata` هر صفحه.
- `ai_content_chunks`: قطعات قابل جست‌وجوی متن.
- `ai_terms`: کلیدواژه‌ها و امتیاز اهمیت.
- `ai_generated_questions`: سوالات احتمالی برای `matching` بهتر.
- `ai_crawl_runs`: وضعیت و آمار اجرای `crawl`.

۱۰ ساختار پایگاه داده

فایل `migration` موجود در مخزن برای جداول AI در مسیر `backend/database/migrations/2026_07_07_ai_knowledge_tables.sql` قرار دارد. `schema` کامل جداول پایه مانند `users`، `tenants`، `sites`، `conversations` و `messages` در مخزن فعلی دیده نمی‌شود، اما از APIها قابل استنباط است.

۱.۱۰ جداول اصلی استنباط‌شده

جدول	نقش در سیستم
<code>plans</code>	تعریف پلن‌ها، محدودیت سایت، <code>agent</code> ، مکالمه ماهانه و قابلیت‌های AI.
<code>tenants</code>	حساب مشتریان و اتصال به پلن.
<code>sites</code>	سایت‌های مشتری، دامنه، <code>site</code> ، <code>key</code> تنظیمات برند و وضعیت AI.
<code>users</code>	کاربران پلن با نقش‌های <code>super</code> ، <code>admin</code> ، <code>customer</code> ، <code>admin</code> ، <code>agent</code> .
<code>agent_site_access</code>	نگاشت دسترسی‌های <code>agent</code> به سایت‌ها.
<code>visitors</code>	بازدیدکنندگان عمومی سایت مشتری.
<code>conversations</code>	مکالمات بازدیدکنندگان با سایت.

پیام‌های agent visitor و AI.	messages
فایل‌های پیوست مرتبط با پیام‌ها.	message_attachments
پاسخ‌های آماده برای تیم پشتیبانی.	quick_replies
دانش دستی و curated مشتری.	knowledge_sources
پیشنهاد‌های AI برای agent.	ai_suggestions
ذخیره داده‌های limiting. rate	api_rate_limits
اعلان‌های پلتفرم.	announcements

۲.۱۰ جداول AI موجود در migration

جدول	شرح
ai_site_settings	تنظیمات AI هر سایت شامل فعال بودن، auto assistant، reply، fallback. و threshold crawl،
ai_crawl_sources	منابع crawl از نوع، prefix path URL یا sitemap.
ai_crawl_runs	وضعیت اجرای crawl، تعداد صفحات موفق/ناموفق، chunkها، terms و سوالات تولیدشده.
ai_pages	صفحات crawl شده، متن پاک‌شده، عنوان، hash heading، محتوا و وضعیت crawl.
ai_content_chunks	قطعات متنی قابل جست‌وجو، category، keywords intent و score. importance
ai_terms	های term استخراج‌شده از chunkها برای boost در matching.
ai_generated_questions	سوالات قالبی تولیدشده از محتوا برای بهبود تطابق سوال visitor.
ai_unanswered_questions	سوالات کم‌اعتماد یا بی‌پاسخ برای بازبینی و بهبود دانش.
ai_answer_logs	لاگ همه تلاش‌های AI شامل، confidence، منابع، متن پاسخ و mode. reply

۱۱ API و گروه‌ها Endpoint

۱.۱۱ گروه Auth

- login.php: ورود و صدور JWT.
- me.php: دریافت کاربر جاری.
- change-password.php: تغییر رمز و افزایش token_version.
- logout-all.php: باطل‌سازی توکن‌های قبلی.

۲.۱۱ گروه Widget

- config.php: دریافت تنظیمات عمومی ویجت و وضعیت پشتیبانی.
- visitor-start.php: ایجاد یا به‌روزرسانی visitor.
- conversation-start.php: ایجاد یا بازیابی conversation با کنترل محدودیت ماهانه.
- message-send.php: ثبت پیام visitor.
- attachment-send.php: ثبت پیام همراه فایل.
- messages-list.php: دریافت پیام‌ها و پیوست‌ها.
- typing-status.php: دریافت وضعیت typing اپراتور.
- ai-reply.php: پاسخ خودکار AI در شرایط مجاز.

۳.۱۱ گروه Agent

این گروه برای اپراتورها و ادمین مشتری استفاده می‌شود و شامل لیست مکالمات، جزئیات مکالمه، ارسال پیام، ارسال فایل، assignment تغییر وضعیت، بستن مکالمه، quick typing، presence، replies و چرخه پیشنهاد AI است.

۴.۱۱ گروه Admin Customer

این گروه مدیریت عملیاتی مشتری را پوشش می‌دهد: سایت‌ها، تنظیمات ویجت، تیم، پلن، گزارش‌ها، quick replies، دانش دستی، تنظیمات AI، منابع، crawl، اجرای crawl، سوالات تولیدشده، سوالات بی‌پاسخ و اعلان‌ها.

۵.۱۱ گروه Admin Super

این گروه کنترل پلتفرم را پوشش می‌دهد: dashboard مشتریان، پلن‌ها، سایت‌ها، وضعیت کاربران، reset رمز، اعلان‌ها و آمار مانیتورینگ AI.

۱۲ Design ها Pattern و تصمیم‌های معماری

۱.۱۲ Endpoint-per-file

هر API در یک فایل مستقل PHP قرار دارد. این الگو پیچیدگی routing را کاهش داده و برای ساخت سریع MVP مناسب است. در مقابل، برای رشد آینده بهتر است مستندسازی endpointها و استانداردسازی includeها جدی گرفته شود.

۲.۱۲ Includes Shared

منطق مشترک به جای تکرار در endpointهای backend/includes قرار گرفته است. نمونه‌ها شامل site-access.php, upload.php, rate-limit.php, response.php, auth.php و plan-limits.php هستند. این الگو نوعی Shared Kernel سبک در بک‌اند ایجاد می‌کند.

۳.۱۲ Repository/Service سبک در Frontend

در پنل Next.js، فایل frontend/lib/api.ts نقش لایه ارتباط مرکزی با API را دارد. این فایل token را از LocalStorage می‌خواند، header احراز هویت را اضافه می‌کند، response JSON را parse می‌کند و در خطای ۴۰۱ کاربر را به login هدایت می‌کند.

۴.۱۲ Access Policy-based

دسترسی‌ها بر اساس ترکیب نقش، site tenant و plan اعمال می‌شوند. این تصمیم برای SaaS چندمستاجری ضروری است، چون فقط احراز هویت کافی نیست و هر درخواست باید نسبت به مرز tenant و site بررسی شود.

۵.۱۲ AI Knowledge-grounded

AI به صورت مستقل از جریان انسانی طراحی نشده است. پاسخ AI بر اساس دانش داخلی، score، log threshold و queue unanswered کنترل می‌شود. این الگو باعث می‌شود AI نقش کمک‌کننده و قابل نظارت داشته باشد.

۱۳ امنیت و کنترل سوءاستفاده

کنترل‌های امنیتی فعلی شامل موارد زیر است:

- JWT برای API پنل.
- access role-based با require_role.
- بررسی فعال بودن user و tenant.
- revocation token با token_version.
- access site برای جلوگیری از دسترسی بین مستاجران.
- CORS جداگانه برای پنل و ویجت.
- validation origin برای ویجت بر اساس دامنه سایت و تنظیمات مجاز.
- limiting rate برای login و endpoint عمومی حساس.
- headers security شامل nosniff، frame، referrer deny، permissions policy، ico و CSP برای APIها.
- validation سخت‌گیرانه فایل‌های آپلودی.
- پنهان‌سازی خطاهای ۵۰۰ در محیط production از طریق handler.response.

۱.۱۳ نکات امنیتی نیازمند بازبینی قبل از تولید

- در crawler فعلی، verification SSL در fetch غیرفعال شده است؛ برای production باید فعال یا با سیاست مشخص کنترل شود.
- مقادیر JWT_SECRET و CORS در production باید حتما جایگزین مقادیر نمونه شوند.
- لازم است های endpoint billing-sensitive و plan-sensitive قبل از عرضه تجاری -au-dit شوند.
- اجرای های crawl بزرگ بهتر است به queue job منتقل شود تا timeout و فشار HTTP request کاهش یابد.

۱۴ Flow Git و مدیریت نسخه

در مخزن فعلی سند رسمی Flow Git دیده نمی‌شود. پیشنهاد فنی برای ادامه توسعه به شکل زیر است:

- شاخه main: نسخه پایدار و قابل ارائه.
 - شاخه develop: ادغام قابلیت‌های آماده تست.
 - شاخه‌های feature/*: توسعه قابلیت‌های جدید مانند billing، تست خودکار یا queue.
 - شاخه‌های hotfix/*: اصلاح فوری خطاهای production.
 - هر merge به main باید با شماره نسخه، changelog کوتاه و تست smoke همراه باشد.
- نسخه‌گذاری پیشنهادی: Semantic Versioning با قالب MAJOR.MINOR.PATCH. برای مثال نسخه اولیه قابل ارائه می‌تواند 0.1.0 باشد و نسخه‌های پایدار تجاری از 1.0.0 شروع شوند.

۱۵ کیفیت، تست و پایش

در فایل‌های بررسی‌شده، ساختار تست خودکار کامل مشاهده نمی‌شود. با توجه به حساسیت محصول، تست‌های زیر باید در اولویت قرار بگیرند:

- تست revocation token و نقش‌ها.
 - تست access site و جلوگیری از IDOR بین tenantها.
 - تست شروع visitor و conversation از ویجت.
 - تست محدودیت مکالمه ماهانه، محدودیت agent و محدودیت سایت.
 - تست ارسال فایل‌های مجاز و رد فایل‌های خطرناک.
 - تست suggestion AI و reply auto با های threshold مختلف.
 - تست loop unanswered و افزودن سوال به knowledge.
- برای پایش production پیشنهاد می‌شود logging ساختاریافته، error، health tracking، check، backup زمان‌بندی‌شده دیتابیس، پایش فضای upload و مانیتورینگ نرخ خطاهای API اضافه شود.

۱۶ محدودیت‌های فعلی و ریسک‌های فنی

موضوع	شرح و پیشنهاد
Schema پایه	migration کامل جداول اصلی در مخزن فعلی دیده نمی‌شود. برای ارائه و استقرار باید schema پایه کامل بسته‌بندی شود.
AI مولد	جریان فعال AI بیشتر استخراجی و rule-based است. این موضوع مزیت کنترل‌پذیری دارد، اما نباید به عنوان LLM کامل معرفی شود مگر endpoint مولد فعال و مستند شود.
Crawler	crawler هم‌اکنون synchronous است و در crawl بزرگ ممکن است timeout شود. پیشنهاد: queue job و worker.
crawler در SSL	SSL verification غیرفعال است. برای production باید بازبینی شود.
Router مرکزی	بک‌اند router مرکزی ندارد. در رشد پروژه، استانداردسازی end-pointها و مستندسازی API اهمیت بیشتری پیدا می‌کند.
تست خودکار	پوشش تست رسمی در مخزن قابل مشاهده نیست. برای بلوغ فنی باید تست‌های حیاتی اضافه شوند.
Billing	ساختار پلن وجود دارد، اما پرداخت و self-service billing در نسخه فعلی دیده نمی‌شود.

۱۷ جمع‌بندی فنی

پروژه SaaS Chat AI از نظر فنی یک MVP پیشرفته و قابل نمایش برای پلتفرم پشتیبانی چندمستاجری است. سیستم دارای سه لایه اصلی بک‌اند، پلن و ویجت است و جریان‌های مهم SaaS شامل مشتری، سایت، کاربر، پلن، مکالمه، گزارش، دانش، AI، فایل پیوست و اعلان را پوشش می‌دهد.

ارزش فنی اصلی پروژه در ترکیب سه قابلیت است: پشتیبانی انسانی، ویجت قابل نصب روی سایت مشتری و AI کنترل‌شده مبتنی بر دانش داخلی. موتور پاسخ‌دهی فعلی به صورت محلی و استخراجی طراحی شده و با ذخیره، confidence source و questions unanswered قابلیت توضیح‌پذیری و بهبود تدریجی دارد.

برای ارائه به پارک علم و فناوری، نقاط قابل تاکید عبارت‌اند از:

- معماری چندمستاجری و جداسازی tenant/site.
- چرخه کامل پشتیبانی انسانی و handoff.
- موتور دانش اختصاصی شامل crawler، term chunking، question extraction، scoring و eration.
- کنترل، plan، site role، access، CORS، limit rate و security upload.
- مسیر روشن برای تکامل محصول شامل queue، تست خودکار، billing monitoring و API documentation.